

controlled.webscan.example

Verified review completed 2026-08-20T16:00:00.000Z. This PDF contains bounded, evidence-based findings only.

POSTURE SCORE	GRADE	ATTENTION	AGENTS
20/100	E	29	15/15

Scope note. This is a bounded defensive posture review for `https://controlled.webscan.example/`. It does not prove the absence of vulnerabilities and does not contain raw cookie values, owner-evidence contents, or private credentials.

Owner evidence

8 redacted owner file(s) were reviewed for this report only. Evidence contents are never included in this PDF.

Coverage

- Verified public response
- Transport and response headers
- Visible cookie attributes
- Sampled HTML asset references
- Public technology hints
- 8 redacted owner-evidence file(s), processed for this review only

Limitations

- No credentialed testing or authentication bypass attempts
- No active exploitation, fuzzing, brute force, or denial-of-service testing
- Source review is limited to the selected redacted excerpts supplied by the owner

How to read the detailed report

Every agent appears in the following pages. A completed agent without an attention item is not proof that its area is vulnerability-free; it simply did not receive a concrete signal in the reviewed material.

Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

AGENT 01

COMPLETE
1 attention

Transport agent

Evidence scope: HTTPS, redirects, HSTS and secure response delivery

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

high confidence · attention

HSTS policy

Observed signal: strict-transport-security was not present in the verified response.

Why it matters

Without HSTS, returning visitors may be more exposed to protocol-downgrade risks.

Required change

Set a reviewed Strict-Transport-Security policy once all subdomains are ready for HTTPS.

Acceptance check

Request a representative protected route and confirm the strict-transport-security response header is present with an appropriate policy.

OWASP ASVS v5.0.0 — Communications Security

Observed controls and limited review notes (1)

- HTTPS transport observed: Verified target responded over HTTPS.

Browser isolation agent

Evidence scope: CSP, framing, MIME and browser permissions

4 concrete evidence-backed attention findings require remediation.

MEDIUM

high confidence · attention

Content Security Policy

Observed signal: content-security-policy was not present in the verified response.

Why it matters

Required change

Acceptance check

A missing CSP removes an important browser-side containment layer against script injection impacts.

Implement a restrictive, tested Content-Security-Policy and progressively remove broad script allowances.

Request a representative protected route and confirm the content-security-policy response header is present with an appropriate policy.

OWASP ASVS v5.0.0 – Encoding and Sanitization

LOW

high confidence · attention

MIME sniffing protection

Observed signal: x-content-type-options was not present in the verified response.

Why it matters

Required change

Acceptance check

Without an explicit no-sniff directive, browsers may infer unexpected content types in edge cases.

Set X-Content-Type-Options: nosniff for relevant responses and validate declared MIME types.

Request a representative protected route and confirm the x-content-type-options response header is present with an appropriate policy.

OWASP ASVS v5.0.0 – File Handling

LOW

high confidence · attention

Permissions policy

Observed signal: permissions-policy was not present in the verified response.

Why it matters

Required change

Acceptance check

Browser features may be available more broadly than the application needs.

Define a Permissions-Policy that disables browser features not required by the product.

Request a representative protected route and confirm the permissions-policy response header is present with an appropriate policy.

OWASP ASVS v5.0.0 — Secure Coding

MEDIUM

high confidence · attention

Framing control is not observed

Observed signal: The verified response did not include X-Frame-Options or a CSP frame-ancestors directive.

Why it matters

Required change

Acceptance check

Without a framing restriction, an application page may be embedded by an untrusted site in ways that can enable deceptive interaction patterns.

Set a reviewed CSP frame-ancestors directive and, where compatible, an X-Frame-Options fallback for sensitive application routes.

Request representative sensitive routes and confirm the framing restriction is returned consistently.

OWASP ASVS v5.0.0 — Browser Security

AGENT 03

COMPLETE
1 attention

Session agent

Evidence scope: Visible cookies and session posture

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

medium confidence · attention

Observed cookie hardening is incomplete

Observed signal: 1 Set-Cookie response value(s) were observed in the verified response; values are intentionally not retained in the report.

Why it matters

Session or state cookies without appropriate browser attributes may have weaker protection against common client-side threats.

Required change

Review each session and sensitive-state cookie; apply Secure, HttpOnly, and an appropriate SameSite setting where compatible with the authentication flow.

Acceptance check

Inspect cookies emitted by sign-in, recovery, and sensitive state transitions without exposing their values in logs.

OWASP ASVS v5.0.0 — Authentication and Session Management

WEBCAN · DETAILED AGENT READOUT · AUTH / AUTHORIZATION / INPUT

Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

AGENT 04

COMPLETE
2 attention

Authentication agent

Evidence scope: Owner-provided authentication evidence

2 concrete evidence-backed attention findings require remediation.

HIGH

high confidence · attention

JWT signing value is embedded in source

Observed signal: Redacted owner evidence contains a JWT signing call with a literal value. No source excerpt is retained in the report.

Why it matters	Required change	Acceptance check
A signing value embedded in source can be copied into builds or source-control history.	Read the JWT signing value from a server-only secret at startup; reject startup when it is missing and rotate the existing value before release.	Add a startup test that fails without the secret and an integration test that accepts tokens signed with the configured replacement value only.

OWASP ASVS v5.0.0 — Authentication

MEDIUM

high confidence · attention

Authentication cookie disables HttpOnly

Observed signal: Redacted owner evidence configures an authentication or session cookie with HttpOnly set to false. No source excerpt is retained in the report.

Why it matters	Required change	Acceptance check
A browser-readable authentication cookie can be exposed to injected client-side script.	SetHttpOnly for authentication and recovery cookies unless a documented architecture makes that impossible; use a separate, non-sensitive client state value when needed.	Add an authentication-flow test that inspects cookie attributes and confirms HttpOnly is present for every session and recovery cookie.

OWASP ASVS v5.0.0 — Authentication and Session Management

AGENT 05

COMPLETE
1 attention

Authorization agent

Evidence scope: Owner-provided role, tenant and ownership evidence

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

high confidence · attention

Client-supplied tenant or object identifier used in a protected lookup

Observed signal: Redacted owner evidence uses a request-provided tenant, account, or object identifier directly in a data lookup. No source excerpt is retained in the report.

Why it matters

A request-controlled identifier can cross a tenant or ownership boundary if the server does not bind it to the authenticated principal.

Required change

Derive tenant and owner context from the authenticated server session and enforce ownership or policy checks before reading or changing the requested object.

Acceptance check

Add tests that request another tenant or user's object identifier and confirm the server returns a denial without leaking object existence.

OWASP ASVS v5.0.0 — Authorization

Input safety agent

Evidence scope: Validation, encoding and unsafe-rendering cues

3 concrete evidence-backed attention findings require remediation.

HIGH

high confidence · attention

HTML form posts to an HTTP action

Observed signal: The sampled HTML contains a form action using http://.

Why it matters

Required change

Acceptance check

A form that submits to HTTP can expose submitted values to an unencrypted transport path.

Replace the HTTP form action with an HTTPS same-origin or explicitly reviewed HTTPS endpoint and enforce HTTPS redirects server-side.

Inspect rendered forms and confirm every action resolves to an HTTPS endpoint before submitting sensitive data.

OWASP ASVS v5.0.0 — Communications Security

HIGH

high confidence · attention

Unsafe dynamic rendering or execution API used

Observed signal: Redacted owner evidence uses a dynamic execution or HTML-rendering API. No source excerpt is retained in the report.

Why it matters

Required change

Acceptance check

Dynamic execution or unsanitized HTML rendering can turn untrusted input into script execution.

Remove the unsafe API where possible; otherwise sanitize untrusted HTML with a maintained sanitizer and keep scripts, event attributes, and dangerous URL schemes disallowed.

Add rendering tests with script tags, event attributes, and javascript: URLs and confirm none execute or render as active content.

OWASP ASVS v5.0.0 — Encoding and Sanitization

HIGH

high confidence · attention

Request-controlled value passed to a shell execution API

Observed signal: Redacted owner evidence passes request-derived input to a shell execution API. No source excerpt is retained in the report.

Why it matters

Shell execution with request-controlled input can turn untrusted data into operating-system command behavior.

Required change

Remove shell execution from request handling where possible; otherwise use a fixed executable with a strict allowlist of arguments and reject unrecognized values before invoking it.

Acceptance check

Add tests that submit unexpected argument strings and confirm no unapproved command or side effect is invoked.

OWASP ASVS v5.0.0 — Injection Prevention

[WEBCAN](#) · [DETAILED AGENT READOUT](#) · [CLIENT](#) / [API](#) / [PRIVACY](#)

Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

Client exposure agent

Evidence scope: Client delivery, metadata and HTTP-resource cues

3 concrete evidence-backed attention findings require remediation.

MEDIUM

medium confidence · attention

Potential HTTP resource reference

Observed signal: The sampled HTML contains at least one http:// resource reference.

Why it matters	Required change	Acceptance check
Insecure subresource references can weaken a secure page or be blocked by browsers.	Replace HTTP resource references with HTTPS sources and add reporting or enforcement through CSP where appropriate.	Review production pages in browser developer tools for mixed-content warnings.

OWASP ASVS v5.0.0 — Communications Security

MEDIUM

medium confidence · attention

Security token stored through browser storage API

Observed signal: The sampled HTML uses a browser storage API with a token-like key name.

Why it matters	Required change	Acceptance check
Tokens reachable by browser JavaScript can have a broader exposure surface if a script-injection issue occurs.	Review whether the token can be replaced with a hardened, HttpOnly cookie flow; if browser storage is required, minimize scope and lifetime and enforce a restrictive CSP.	Review the authenticated client flow and confirm that high-value credentials are not persisted in browser-readable storage without a documented compensating control.

OWASP ASVS v5.0.0 — Authentication and Session Management

MEDIUM

high confidence · attention

Token-like value persisted in browser-readable storage

Observed signal: Redacted owner evidence stores a token-like value through localStorage or sessionStorage. No source excerpt is retained in the report.

Why it matters

A token in browser-readable storage can have a broader exposure surface if client-side script is compromised.

Required change

Prefer a hardened HttpOnly cookie flow for high-value credentials; otherwise minimize token privilege and lifetime and enforce CSP to reduce script-injection impact.

Acceptance check

Review the authenticated client flow and confirm high-value credentials are not persisted in browser-readable storage without an approved compensating control.

OWASP ASVS v5.0.0 — Authentication and Session Management

Observed controls and limited review notes (1)

- **Technology disclosure:** No Server or X-Powered-By response hint was observed.

AGENT 08

COMPLETE
1 attention

API & error agent

Evidence scope: Route and error-handling evidence

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

high confidence · attention

Request-controlled redirect target

Observed signal: Redacted owner evidence redirects a client using a request-supplied query, body, or path value. No source excerpt is retained in the report.

Why it matters

A request-controlled redirect can send users to untrusted destinations and may be abused in phishing or token-handling flows.

Required change

Replace direct request-controlled redirects with a strict same-origin route allowlist or a validated list of approved external destinations.

Acceptance check

Add tests that reject unapproved absolute URLs, protocol-relative URLs, and malformed return targets while accepting approved application routes.

OWASP ASVS v5.0.0 — Secure Coding

AGENT 09

COMPLETE
1 attention

Data privacy agent

Evidence scope: Referrer and sensitive-data handling cues

1 concrete evidence-backed attention finding requires remediation.

LOW

high confidence · attention

Referrer policy

Observed signal: referrer-policy was not present in the verified response.

Why it matters

Sensitive paths or query parameters can be disclosed to destinations through browser referrer behavior.

Required change

Set a reviewed Referrer-Policy such as strict-origin-when-cross-origin, subject to product requirements.

Acceptance check

Request a representative protected route and confirm the referrer-policy response header is present with an appropriate policy.

OWASP ASVS v5.0.0 — Data Protection

[WEBCAN](#) · [DETAILED AGENT READOUT](#) · [CONFIG](#) / [DEPENDENCIES](#) / [SUPPLY-CHAIN](#)

Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

Configuration hygiene agent

Evidence scope: Redacted configuration template evidence

3 concrete evidence-backed attention findings require remediation.

MEDIUM

high confidence · attention

Wildcard credentialed CORS response observed

Observed signal: The verified response combines Access-Control-Allow-Origin: * with Access-Control-Allow-Credentials: true.

Why it matters	Required change	Acceptance check
This CORS configuration is unsafe to rely on and can create inconsistent cross-origin behavior around credentialed browser requests.	Replace the wildcard with a strict origin allowlist, return a single validated origin, and send credentialed CORS headers only for reviewed flows that require them.	Add integration tests that accept approved origins and reject unapproved origins for both preflight and credentialed requests.

OWASP ASVS v5.0.0 — Secure Coding

MEDIUM

high confidence · attention

Wildcard CORS policy configured

Observed signal: Redacted owner evidence configures a wildcard CORS origin. No source excerpt is retained in the report.

Why it matters	Required change	Acceptance check
A wildcard cross-origin policy can expose browser-readable responses more broadly than intended.	Replace the wildcard with an explicit allowlist of trusted origins and keep credentialed requests disabled unless a reviewed product flow requires them.	Add tests that allow each approved origin and reject an unapproved origin, including credentialed preflight behavior.

OWASP ASVS v5.0.0 — Secure Coding

HIGH

high confidence · attention

TLS certificate validation disabled

Observed signal: Redacted owner evidence disables Node.js TLS certificate validation. No source excerpt is retained in the report.

Why it matters

Disabling certificate validation can allow connections that fail normal TLS trust checks.

Required change

Remove the override, trust only the required certificate authority chain, and fail closed when TLS validation cannot succeed.

Acceptance check

Add a configuration test that fails when TLS validation is disabled and a connection test that rejects an untrusted certificate.

OWASP ASVS v5.0.0 — Communications Security

AGENT 11

COMPLETE
2 attention

Dependency agent

Evidence scope: Manifest and lockfile evidence

2 concrete evidence-backed attention findings require remediation.

MEDIUM

high confidence · attention

Unbounded dependency version range

Observed signal: Redacted owner evidence contains a latest, wildcard, or early 0.x dependency range. No source excerpt is retained in the report.

Why it matters Unbounded or early-version ranges make dependency changes harder to review and reproduce.	Required change Replace the range with a reviewed stable version, commit the lockfile, and update through a tested dependency-review process.	Acceptance check Add CI validation that requires a lockfile and fails if production dependencies use latest or wildcard ranges.
--	---	---

OWASP ASVS v5.0.0 — Dependency Management

LOW

high confidence · attention

Dependency lifecycle install script declared

Observed signal: Redacted owner evidence declares a preinstall, install, postinstall, or prepare lifecycle script. No source excerpt is retained in the report.

Why it matters Lifecycle scripts execute automatically during installation and should be reviewed as part of dependency and build trust decisions.	Required change Document the script purpose, keep it minimal and deterministic, and review it together with lockfile changes; avoid downloading or executing unverified remote content.	Acceptance check Add CI policy that lists lifecycle scripts for review and blocks unapproved remote installer pipes.
--	---	--

OWASP ASVS v5.0.0 — Dependency Management

AGENT 12

COMPLETE
2 attention

Supply-chain agent

Evidence scope: Build, CI and release evidence

2 concrete evidence-backed attention findings require remediation.

HIGH

high confidence · attention

Privileged or unpinned workflow installation pattern

Observed signal: Redacted owner evidence contains pull_request_target or a remote installer pipe. No source excerpt is retained in the report.

Why it matters	Required change	Acceptance check
Privileged pull-request workflows or remote installer pipes can execute unreviewed code in the build environment.	Replace the privileged trigger with an unprivileged pull-request workflow and pin reviewed actions or installer checksums instead of piping remote content to a shell.	Add a workflow policy test that rejects pull_request_target and curl-pipe-shell patterns in CI configuration.

OWASP ASVS v5.0.0 — Secure Development

MEDIUM

high confidence · attention

Workflow grants broad write permissions

Observed signal: Redacted owner evidence grants write-all or broad contents write permissions to a CI workflow. No source excerpt is retained in the report.

Why it matters	Required change	Acceptance check
Broad workflow tokens increase the impact of a compromised build step or unsafe pull-request trigger.	Set workflow permissions to read-only by default and grant the smallest explicit write permission only to the isolated job that requires it.	Add CI policy that rejects write-all and verifies every workflow job has the minimum documented permission set.

OWASP ASVS v5.0.0 — Secure Development

WEBCAN · DETAILED AGENT READOUT · DEPLOYMENT / LOGGING / STORAGE

Agent findings & remediation

Each agent reports only what its available evidence supports. Attention findings contain a specific required change and an acceptance check; no generic remediation is invented.

AGENT 13

COMPLETE
2 attention

Deployment agent

Evidence scope: Redacted runtime and hosting configuration

2 concrete evidence-backed attention findings require remediation.

HIGH

high confidence · attention

Privileged container runtime configured

Observed signal: Redacted owner evidence enables privileged or root container execution. No source excerpt is retained in the report.

Why it matters	Required change	Acceptance check
A privileged or root runtime increases the impact of a service compromise.	Run the service as a dedicated non-root user, remove privileged mode, and drop unnecessary Linux capabilities in the deployment configuration.	Add a deployment policy check that rejects privileged mode, root user, and runAsNonRoot: false.

OWASP ASVS v5.0.0 – Configuration

HIGH

high confidence · attention

Container adds all Linux capabilities or host networking

Observed signal: Redacted owner evidence enables host networking or adds all Linux capabilities to a container. No source excerpt is retained in the report.

Why it matters	Required change	Acceptance check
Host networking or broad Linux capabilities expand the impact of a container compromise.	Remove host networking and unnecessary capabilities; use the smallest network, filesystem, and capability permissions required by the service.	Add a deployment policy check that rejects hostNetwork: true and capability additions of ALL.

OWASP ASVS v5.0.0 – Configuration

AGENT 14

COMPLETE
1 attention

Logging & recovery agent

Evidence scope: Logging and recovery-flow evidence

1 concrete evidence-backed attention finding requires remediation.

MEDIUM

high confidence · attention

Sensitive personal field written to logs

Observed signal: Redacted owner evidence logs an email address, social-security identifier, or payment-card field. No source excerpt is retained in the report.

Why it matters	Required change	Acceptance check
Personal or payment data in logs can outlive the transaction and broaden access to sensitive information.	Remove the sensitive field from the log event, retain only a non-sensitive correlation identifier, and enforce central structured-log redaction.	Add a captured-log test that confirms email, identity, and payment fields do not appear in emitted logs.

OWASP ASVS v5.0.0 — Logging and Data Protection

AGENT 15

COMPLETE
2 attention

Storage & cryptography agent

Evidence scope: Storage, cryptography and lifecycle evidence

2 concrete evidence-backed attention findings require remediation.

HIGH

high confidence · attention

Deprecated hash used for a password or secret

Observed signal: Redacted owner evidence uses MD5 or SHA-1 in a password or secret-handling context. No source excerpt is retained in the report.

Why it matters

MD5 and SHA-1 are not suitable password-protection primitives and can weaken stored-secret protection.

Required change

Replace the deprecated hash with a maintained password-hashing API such as Argon2id or scrypt, use per-password salts, and migrate existing hashes at successful login.

Acceptance check

Add tests that create and verify a new password hash with the approved algorithm and reject legacy MD5/SHA-1 password hashes.

OWASP ASVS v5.0.0 — Cryptography and Data Protection

HIGH

high confidence · attention

Static initialization vector pattern in encryption code

Observed signal: Redacted owner evidence uses a zero-filled or fixed initialization vector in an encryption call. No source excerpt is retained in the report.

Why it matters

A fixed initialization vector can undermine the security properties expected from many encryption modes.

Required change

Generate a fresh cryptographically random initialization vector for each encryption operation, store it with the ciphertext when needed, and use an authenticated encryption mode.

Acceptance check

Add tests that encrypt the same plaintext twice and confirm distinct IVs and ciphertexts are produced while both values decrypt successfully.

OWASP ASVS v5.0.0 — Cryptography and Data Protection

Remediation prompt

This consolidated implementation brief contains the agent evidence and corrective work documented in the previous pages. It preserves the report's defensive limits.

You are improving the security of the authorized web application at `https://controlled.webscan.example/`.

Scope and evidence:

- This is a defensive remediation task based on a bounded WebScan review.
- Coverage: Verified public response; Transport and response headers; Visible cookie attributes; Sampled HTML asset references; Public technology hints; 8 redacted owner-evidence file(s), processed for this review only
- Limitations: No credentialed testing or authentication bypass attempts; No active exploitation, fuzzing, brute force, or denial-of-service testing; Source review is limited to the selected redacted excerpts supplied by the owner

Prioritized remediation objectives:

Transport agent

1. HSTS policy [medium]
 - Observed signal: `strict-transport-security` was not present in the verified response.
 - Required change: Set a reviewed `Strict-Transport-Security` policy once all subdomains are ready for HTTPS.
 - Acceptance check: Request a representative protected route and confirm the `strict-transport-security` response header is present with an appropriate policy.

Browser isolation agent

1. Content Security Policy [medium]
 - Observed signal: `content-security-policy` was not present in the verified response.
 - Required change: Implement a restrictive, tested `Content-Security-Policy` and progressively remove broad script allowances.
 - Acceptance check: Request a representative protected route and confirm the `content-security-policy` response header is present with an appropriate policy.
2. MIME sniffing protection [low]
 - Observed signal: `x-content-type-options` was not present in the verified response.
 - Required change: Set `X-Content-Type-Options: nosniff` for relevant responses and validate declared MIME types.
 - Acceptance check: Request a representative protected route and confirm the `x-content-type-options` response header is present with an appropriate policy.
3. Permissions policy [low]
 - Observed signal: `permissions-policy` was not present in the verified response.
 - Required change: Define a `Permissions-Policy` that disables browser features not required by the product.
 - Acceptance check: Request a representative protected route and confirm the `permissions-policy` response header is present with an appropriate policy.
4. Framing control is not observed [medium]
 - Observed signal: The verified response did not include `X-Frame-Options` or a CSP `frame-ancestors` directive.
 - Required change: Set a reviewed CSP `frame-ancestors` directive and, where compatible, an `X-Frame-Options` fallback for sensitive application routes.
 - Acceptance check: Request representative sensitive routes and confirm the framing restriction is returned consistently.

Data privacy agent

1. Referrer policy [low]

- Observed signal: referrer-policy was not present in the verified response.
- Required change: Set a reviewed Referrer-Policy such as strict-origin-when-cross-origin, subject to product requirements.
- Acceptance check: Request a representative protected route and confirm the referrer-policy response header is present with an appropriate policy.

Session agent

1. Observed cookie hardening is incomplete [medium]

- Observed signal: 1 Set-Cookie response value(s) were observed in the verified response; values are intentionally not retained in the report.
- Required change: Review each session and sensitive-state cookie; apply Secure, HttpOnly, and an appropriate SameSite setting where compatible with the authentication flow.
- Acceptance check: Inspect cookies emitted by sign-in, recovery, and sensitive state transitions without exposing their values in logs.

Client exposure agent

1. Potential HTTP resource reference [medium]

- Observed signal: The sampled HTML contains at least one http:// resource reference.
- Required change: Replace HTTP resource references with HTTPS sources and add reporting or enforcement through CSP where appropriate.
- Acceptance check: Review production pages in browser developer tools for mixed-content warnings.

2. Security token stored through browser storage API [medium]

- Observed signal: The sampled HTML uses a browser storage API with a token-like key name.
- Required change: Review whether the token can be replaced with a hardened, HttpOnly cookie flow; if browser storage is required, minimize scope and lifetime and enforce a restrictive CSP.
- Acceptance check: Review the authenticated client flow and confirm that high-value credentials are not persisted in browser-readable storage without a documented compensating control.

3. Token-like value persisted in browser-readable storage [medium]

- Observed signal: Redacted owner evidence stores a token-like value through localStorage or sessionStorage. No source excerpt is retained in the report.
- Required change: Prefer a hardened HttpOnly cookie flow for high-value credentials; otherwise minimize token privilege and lifetime and enforce CSP to reduce script-injection impact.
- Acceptance check: Review the authenticated client flow and confirm high-value credentials are not persisted in browser-readable storage without an approved compensating control.

Input safety agent

1. HTML form posts to an HTTP action [high]

- Observed signal: The sampled HTML contains a form action using http://.
- Required change: Replace the HTTP form action with an HTTPS same-origin or explicitly reviewed HTTPS endpoint and enforce HTTPS redirects server-side.
- Acceptance check: Inspect rendered forms and confirm every action resolves to an HTTPS endpoint before submitting sensitive data.

2. Unsafe dynamic rendering or execution API used [high]

- Observed signal: Redacted owner evidence uses a dynamic execution or HTML-rendering API. No source excerpt is retained in the report.
- Required change: Remove the unsafe API where possible; otherwise sanitize untrusted HTML with a maintained sanitizer and keep scripts, event attributes, and dangerous URL schemes disallowed.
- Acceptance check: Add rendering tests with script tags, event attributes, and

javascript: URLs and confirm none execute or render as active content.

3. Request-controlled value passed to a shell execution API [high]

- Observed signal: Redacted owner evidence passes request-derived input to a shell execution API. No source excerpt is retained in the report.
- Required change: Remove shell execution from request handling where possible; otherwise use a fixed executable with a strict allowlist of arguments and reject unrecognized values before invoking it.
- Acceptance check: Add tests that submit unexpected argument strings and confirm no unapproved command or side effect is invoked.

Configuration hygiene agent

1. Wildcard credentialed CORS response observed [medium]

- Observed signal: The verified response combines Access-Control-Allow-Origin: * with Access-Control-Allow-Credentials: true.
- Required change: Replace the wildcard with a strict origin allowlist, return a single validated origin, and send credentialed CORS headers only for reviewed flows that require them.
- Acceptance check: Add integration tests that accept approved origins and reject unapproved origins for both preflight and credentialed requests.

2. Wildcard CORS policy configured [medium]

- Observed signal: Redacted owner evidence configures a wildcard CORS origin. No source excerpt is retained in the report.
- Required change: Replace the wildcard with an explicit allowlist of trusted origins and keep credentialed requests disabled unless a reviewed product flow requires them.
- Acceptance check: Add tests that allow each approved origin and reject an unapproved origin, including credentialed preflight behavior.

3. TLS certificate validation disabled [high]

- Observed signal: Redacted owner evidence disables Node.js TLS certificate validation. No source excerpt is retained in the report.
- Required change: Remove the override, trust only the required certificate authority chain, and fail closed when TLS validation cannot succeed.
- Acceptance check: Add a configuration test that fails when TLS validation is disabled and a connection test that rejects an untrusted certificate.

Authentication agent

1. JWT signing value is embedded in source [high]

- Observed signal: Redacted owner evidence contains a JWT signing call with a literal value. No source excerpt is retained in the report.
- Required change: Read the JWT signing value from a server-only secret at startup; reject startup when it is missing and rotate the existing value before release.
- Acceptance check: Add a startup test that fails without the secret and an integration test that accepts tokens signed with the configured replacement value only.

2. Authentication cookie disables HttpOnly [medium]

- Observed signal: Redacted owner evidence configures an authentication or session cookie with HttpOnly set to false. No source excerpt is retained in the report.
- Required change: Set HttpOnly for authentication and recovery cookies unless a documented architecture makes that impossible; use a separate, non-sensitive client state value when needed.
- Acceptance check: Add an authentication-flow test that inspects cookie attributes and confirms HttpOnly is present for every session and recovery cookie.

Dependency agent

1. Unbounded dependency version range [medium]

- Observed signal: Redacted owner evidence contains a latest, wildcard, or early 0.x dependency range. No source excerpt is retained in the report.
- Required change: Replace the range with a reviewed stable version, commit the lockfile, and update through a tested dependency-review process.
- Acceptance check: Add CI validation that requires a lockfile and fails if production

dependencies use latest or wildcard ranges.

2. Dependency lifecycle install script declared [low]

- Observed signal: Redacted owner evidence declares a preinstall, install, postinstall, or prepare lifecycle script. No source excerpt is retained in the report.
- Required change: Document the script purpose, keep it minimal and deterministic, and review it together with lockfile changes; avoid downloading or executing unverified remote content.
- Acceptance check: Add CI policy that lists lifecycle scripts for review and blocks unapproved remote installer pipes.

Supply-chain agent

1. Privileged or unpinned workflow installation pattern [high]

- Observed signal: Redacted owner evidence contains pull_request_target or a remote installer pipe. No source excerpt is retained in the report.
- Required change: Replace the privileged trigger with an unprivileged pull-request workflow and pin reviewed actions or installer checksums instead of piping remote content to a shell.
- Acceptance check: Add a workflow policy test that rejects pull_request_target and curl-pipe-shell patterns in CI configuration.

2. Workflow grants broad write permissions [medium]

- Observed signal: Redacted owner evidence grants write-all or broad contents write permissions to a CI workflow. No source excerpt is retained in the report.
- Required change: Set workflow permissions to read-only by default and grant the smallest explicit write permission only to the isolated job that requires it.
- Acceptance check: Add CI policy that rejects write-all and verifies every workflow job has the minimum documented permission set.

Deployment agent

1. Privileged container runtime configured [high]

- Observed signal: Redacted owner evidence enables privileged or root container execution. No source excerpt is retained in the report.
- Required change: Run the service as a dedicated non-root user, remove privileged mode, and drop unnecessary Linux capabilities in the deployment configuration.
- Acceptance check: Add a deployment policy check that rejects privileged mode, root user, and runAsNonRoot: false.

2. Container adds all Linux capabilities or host networking [high]

- Observed signal: Redacted owner evidence enables host networking or adds all Linux capabilities to a container. No source excerpt is retained in the report.
- Required change: Remove host networking and unnecessary capabilities; use the smallest network, filesystem, and capability permissions required by the service.
- Acceptance check: Add a deployment policy check that rejects hostNetwork: true and capability additions of ALL.

Storage & cryptography agent

1. Deprecated hash used for a password or secret [high]

- Observed signal: Redacted owner evidence uses MD5 or SHA-1 in a password or secret-handling context. No source excerpt is retained in the report.
- Required change: Replace the deprecated hash with a maintained password-hashing API such as Argon2id or scrypt, use per-password salts, and migrate existing hashes at successful login.
- Acceptance check: Add tests that create and verify a new password hash with the approved algorithm and reject legacy MD5/SHA-1 password hashes.

2. Static initialization vector pattern in encryption code [high]

- Observed signal: Redacted owner evidence uses a zero-filled or fixed initialization vector in an encryption call. No source excerpt is retained in the report.
- Required change: Generate a fresh cryptographically random initialization vector for each encryption operation, store it with the ciphertext when needed, and use an authenticated encryption mode.

- Acceptance check: Add tests that encrypt the same plaintext twice and confirm distinct IVs and ciphertexts are produced while both values decrypt successfully.

Authorization agent

1. Client-supplied tenant or object identifier used in a protected lookup [medium]
 - Observed signal: Redacted owner evidence uses a request-provided tenant, account, or object identifier directly in a data lookup. No source excerpt is retained in the report.
 - Required change: Derive tenant and owner context from the authenticated server session and enforce ownership or policy checks before reading or changing the requested object.
 - Acceptance check: Add tests that request another tenant or user's object identifier and confirm the server returns a denial without leaking object existence.

API & error agent

1. Request-controlled redirect target [medium]
 - Observed signal: Redacted owner evidence redirects a client using a request-supplied query, body, or path value. No source excerpt is retained in the report.
 - Required change: Replace direct request-controlled redirects with a strict same-origin route allowlist or a validated list of approved external destinations.
 - Acceptance check: Add tests that reject unapproved absolute URLs, protocol-relative URLs, and malformed return targets while accepting approved application routes.

Logging & recovery agent

1. Sensitive personal field written to logs [medium]
 - Observed signal: Redacted owner evidence logs an email address, social-security identifier, or payment-card field. No source excerpt is retained in the report.
 - Required change: Remove the sensitive field from the log event, retain only a non-sensitive correlation identifier, and enforce central structured-log redaction.
 - Acceptance check: Add a captured-log test that confirms email, identity, and payment fields do not appear in emitted logs.

Implementation constraints:

- Preserve existing product behavior and user flows.
- Do not add tracking, weaken authentication, hardcode secrets, or expose private data in logs.
- Prefer framework-native security controls and server-side enforcement.
- Add or update automated tests for every changed security behavior.
- Validate headers, cookies, error handling, and authorization boundaries where relevant.
- Return a concise change summary, affected files, tests run, and any remaining assumptions.
- Do not include exploit payloads, attack automation, or instructions for bypassing controls.

Safety constraints retained. The implementation must not add tracking, weaken authentication, hardcode secrets, expose private data in logs, or include exploit payloads, attack automation, or bypass instructions.